

Critical risk. The check is incomplete.

How serious is it?

NoneLowModerateHighCritical

Critical

Act now.

A remote caller reaches the flawed parser and nothing else in the tree limits it.

How complete is the check?

IncompleteMostlyComplete

Incomplete

The review didn't use 4 of 40 automated scan result groups, and 1 area was only partly checked.

What we need from you

Hold public exposure until the two fixes to sign-in and data queries land.

Effort: Small

Why: Anyone on the internet could otherwise take over a signed-in session or read stored records.

What was checked

Sign-in and sessions	Checked
Data queries	Checked
Deployment images	Partly checked
Second opinion on 4 conclusions	3 confirmed, 1 overturned
Automated scans (3 ran)	36 of 40 result groups used

3 findings need attention; the working summary on the next page lists them.

Summary

The service is not safe to expose to the public internet without two fixes to its auth and query paths.

Two defects in the service's authentication and query paths must be fixed before it is exposed to the public internet; both are reachable by any unauthenticated client. Four further issues are hardening rather than exploitable weaknesses, and two behaviours the owner has accepted are recorded as such. Nothing was executed — every conclusion rests on reading the code at this commit.

Why this rating

Finding	Reachable	Worst outcome	Attacker needs	Level	Answered by
1. The session token is compared in variable time on every authenticated request	Yes	Data exposed	Anyone remote	Critical	Review
2. A caller-supplied sort column reaches the query builder unvalidated	Yes	Data exposed	Anyone remote	Critical	Review
3. Base images are referenced by mutable tags	Unknown	Code runs	Project files	Low to high	Closeout

Needs attention

	Severity	Finding	Where
1	High	The session token is compared in variable time on every authenticated request	internal/auth/session.go:88 +1
2	High	A caller-supplied sort column reaches the query builder unvalidated	internal/store/query.go:214 +1
3	Medium	Base images are referenced by mutable tags	Dockerfile:2

Overtaken by the review

Status	Claim	Id
Refuted	Health and metrics routes disclose tenant data	app-3

Confirmed by the review

Status	Claim	Id
Survives	Session token compared in variable time	app-1
Survives	Sort column reaches the query builder unvalidated	app-2
Survives	Base images referenced by mutable tags	infra-1

Examined and sound

Finding	What was sound
4	Health and metrics routes are unauthenticated by design

Remaining work

- 4 of 40 scanner result groups have no assessment and no set-aside. Unassessed is not cleared.
- Areas only partly checked: Deployment images.

Scanner limitations

- Recorded scanner limits: sast could not fully analyze 12 constructs in 3 files.

Assessed exclusions

- 30 result groups accounted for: test fixtures

Scope and limits

- Static review only. Nothing was executed and no exploit was attempted.
- Dependency advisories were not checked against a live database; run govulncheck before release.
- The browser client is a separate repository and was not surveyed.

Contents

Findings	3
Assessment	4
Security survey: acme/app	4
Adjudication	5
Scanner findings	6
Visuals	6
Evidence appendix	6
Sources	8
About this document	8

Findings

1. The session token is compared in variable time on every authenticated request

Needs action **High** Survives app-1

Impact An attacker who can measure response latency recovers a valid session token a byte at a time, from anywhere the service is reachable.

Action Compare the presented token with the stored digest using a constant-time helper. The digest is already fixed width, so nothing else changes.

Where internal/auth/session.go:88 · read#2

2. A caller-supplied sort column reaches the query builder unvalidated

Needs action **High** Survives app-2

Impact A request can inject SQL into the ORDER BY clause of an otherwise parameterised statement, reading or altering any row the service can reach.

Action Take the sort column from a fixed allowlist rather than from the request, and bind the remaining parameters.

Where internal/store/query.go:214 · internal/api/handlers.go:71

3. Base images are referenced by mutable tags

Needs action **Medium** Survives infra-1

Impact A rebuild can silently change the base image, and the resulting digest is not recorded anywhere.

Action Pin both stages to SHA256 digests and verify them at build time.

Where Dockerfile:2

4. Health and metrics routes are unauthenticated by design

Sound Refuted app-3

Impact The exposed counters carry no tenant identifiers and no request paths, so under the stated threat model this is hardening rather than disclosure.

Action No action needed. Operators who do not want the counters public should place them behind a proxy.

Where `internal/api/server.go:64`

Assessment

Security survey: acme/app

A read-only survey ran in two parallel passes — application code and deployment configuration — followed by a skeptical review of what they returned. No unauthenticated remote exploitability was found, but four issues should be fixed or documented before the service is exposed to the public internet.

Verified issues

Severity	File	Line
High	<code>internal/auth/session.go</code>	88
Issue Session token compared with <code>==</code> . <code>validate()</code> compares the presented bearer token to the stored digest with an ordinary string comparison, which returns as soon as two bytes differ. The comparison is reachable on every authenticated request. What to do Compare with <code>subtle.ConstantTimeCompare</code> . The digest is already fixed width, so no other change is needed.		
High	<code>internal/store/query.go</code>	214
Issue User input concatenated into a query. <code>listByOwner</code> builds its WHERE clause with <code>fmt.Sprintf</code> from a caller-supplied sort column. The column is not validated against a set of known names. What to do Bind parameters, and take the sort column from a fixed allowlist rather than from the request.		
Medium	<code>internal/config/paths.go</code>	136
Issue Relative paths resolved without canonicalisation. <code>resolve()</code> joins configured paths to the config directory with no <code>..</code> handling, so a config writer can address any file the process can read. What to do Canonicalise with <code>filepath.EvalSymlinks</code> and reject anything that escapes the base directory.		
Medium	<code>internal/api/server.go</code>	130
Issue Loopback auth bypass by default. When no bearer token is configured and the listener is bound to loopback, authentication is silently omitted. This is intentional, but loopback is not a trust boundary on a shared host. What to do Make the bypass opt-in behind an explicit <code>allow_unauthenticated_loopback</code> flag.		

Accepted by the service owner

- **Unauthenticated `/healthz` and `/metrics`** (`internal/api/server.go:64`) expose synthetic status and Prometheus counters only. This is a common pattern; operators who do not want the counters public should put them behind a proxy.
- **Five-second config reload** (`internal/config/paths.go:121`) is deliberate, so `ConfigMap` updates land without a restart. It is a tuning knob, not a weakness.

Deployment hardening

Severity	File	Line
Medium	<code>Dockerfile</code>	2, 8
Issue Base images are referenced by mutable tags (<code>goLang:1.26-bookworm</code> , <code>debian:bookworm-slim</code>). What to do Pin to SHA256 digests and verify them at build time.		

Severity	File	Line
Low	deploy/kubernetes.yaml	17
	Issue securityContext does not set runAsUser or runAsGroup, though the image ships USER 65532:65532.	
	What to do Set both explicitly so a rebuilt image cannot change the runtime UID.	
Low	.github/workflows/ci.yml	14, 18
	Issue Actions are pinned to moving tags (@v4, @v2).	
	What to do Pin to full commit SHAs and let Dependabot propose the moves.	

Recommended order

```
// internal/auth/session.go – the whole fix
if subtle.ConstantTimeCompare([]byte(presented), []byte(stored)) == 1 {
    return true
}
```

The query builder change is larger: the sort column has to reach the builder as an enum rather than as text.

Adjudication

Claims

Claimed

Naming the candidate claims · recorded 8 July 2026, 14:51 UTC

Threat model

A public HTTP service. Unauthenticated clients on the open internet may reach every route; the session cookie is the only auth boundary. Assume the attacker can read the published source, so secrets in the repository or in git history are already lost. Operators are trusted; anyone able to write the deployment config is treated as an operator.

Claim	Statement
app-1	Session token compared in variable time. The session token is compared with a non-constant-time string comparison on every authenticated request, which leaks the token a byte at a time to an attacker who can measure response latency. internal/auth/session.go:88
app-2	Sort column reaches the query builder unvalidated. A caller-supplied sort column reaches the query builder unvalidated, so a request can inject SQL into the WHERE clause of an otherwise parameterised statement. internal/store/query.go:214 · internal/api/handlers.go:71
app-3	Health and metrics routes disclose tenant data. Health and metrics routes are intentionally unauthenticated and expose only synthetic status; this is a hardening consideration rather than a vulnerability. internal/api/server.go:64
infra-1	Base images referenced by mutable tags. Mutable base image tags are a supply-chain hardening concern rather than an exploitable application defect, and the deployment already pins its own image by digest. Dockerfile:2

Challenge

Challenged

Challenging the claims · recorded 8 July 2026, 14:58 UTC

Claim	Status	Statement
app-1	Survives	The early-return comparison is reachable on every authenticated request and the digest is fixed width, so the timing signal is not masked by length. Remote measurement over a LAN remains practical. read#2
app-2	Survives	The sort column reaches the builder from the query string with no allowlist between them; the surrounding statement being parameterised does not protect the ORDER BY clause. internal/store/query.go:214
app-3	Refuted	The exposed counters carry no tenant identifiers and no request paths, so under the stated threat model this is hardening rather than disclosure. internal/api/server.go:64
infra-1	Survives	The tag is resolved at build time and the resulting digest is not recorded, so a rebuild can silently change the base image. This is weaker than the application findings but real. Dockerfile:2

Scanner findings

3 rows under 3 rules · opengrep reported 148 findings · 2 ignored by this project · 4 merged into advisories · 104 withheld at ingest · 37 not represented by listed groups · 1 high, 2 medium, 145 info

Severity	Rule or advisory	Occurrences
High	go.lang.security.audit.crypto.use-of-weak-comparison Session token compared with a variable-time equality operator. internal/auth/session.go 88	opengrep 1 occurrence
Medium	dockerfile.security.missing-user Final stage does not set a non-root USER. Dockerfile 8	opengrep 1 occurrence
Medium	go.lang.security.audit.sqli.string-formatted-query Query built with fmt.Sprintf from a caller-supplied identifier. internal/store/query.go 214	opengrep 1 occurrence

Visuals

Signup — empty state



Evidence appendix

7 of 31 records listed · 5 cited · 2 grep, 3 read, 1 list, 1 web

2 Grep records · all structured

Handle	Location	Matches	Cited by
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:grep#4	internal/auth	16 matches in 3 files session.go:88: if presented == stored {	report
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:grep#6	internal/store	4 matches in 1 file query.go:214: clause := fmt.Sprintf("WHERE owner = ? ORDER BY %s", sortColumn)	

3 Read records · all structured

Handle	Location	Cited by
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:read#2	internal/auth/session.go:84-92 84 func (s *Store) validate(presented string) bool { 85 stored := s.digestFor(presented) 86 if presented == stored { 87 return true 88 } 89 return false 90 }	report, app-1, challenge
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:read#5	internal/store/query.go:210-218 210 func (s *Store) listByOwner(owner, sortColumn string) ([]Row, error) { 211 // sortColumn arrives from the request query string. 214 clause := fmt.Sprintf("WHERE owner = ? ORDER BY %s", sortColumn)	report, app-2
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:read#9	Dockerfile:1-5 1 FROM golang:1.26-bookworm AS build 2 WORKDIR /src 3 COPY go.mod go.sum ./ 4 RUN go build -o /out/app ./cmd/app 5 FROM debian:bookworm-slim	report, infra-1

1 List record · none cited · all structured

Handle	Location
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:list#1	deploy

1 Web record · all cited by report · all observed

Handle	Page
8c41f7ad-2b6e-4d90-9f13-05aa7c6e4b21:web#3	https://owasp.org/www-community/attacks/SQL_Injection Timing attacks against HMAC verification remain practical over a LAN when the comparison short-circuits.

Login form after submit



Login form (repeat cite) — see appendix

Sources

Source	Host	Cited by
SQL injection	owasp.org	report
	https://owasp.org/www-community/attacks/SQL_Injection	
subtle.ConstantTimeCompare	pkg.go.dev	report, challenge
	https://pkg.go.dev/crypto/subtle#ConstantTimeCompare	
https://docs.docker.com/build/building/best-practices/	docs.docker.com	challenge

About this document

Produced by	Painted Wolf Code, paintedwolf.ai
Workflow	security-survey 1.0.0
Run	6f2c1d84-9b30-4f51-a7e2-1c8d5b0a3e77
Project	acme/app
Head	a1b2c3d4e5f60718293a4b5c6d7e8f9012345678
Started	8 July 2026, 14:23 UTC
Completed	8 July 2026, 15:04 UTC
Model	claude-opus-5 via anthropic
Workers	4 legs: security-reviewer x2, skeptic x1, web-researcher x1
Scanners	opengrep
Evidence	31 records observed, 7 listed

This document is a projection of the run's durable records — its closeout, review verdicts, scan findings, evidence ledger, and visuals — rendered deterministically: the same records produce byte-identical output. The records, not the document, are the record of the outcome.